

AI Security Trends Report

Квартал 2026-Q2

2026-04-01 — 2026-06-30

Сравнение: vs 2026-Q1

Executive Brief

Подробный квартальный обзор трендов AI Security и смежных технологий (агенты, MCP, self-evolving systems) для руководства и CISO.

Дата подготовки: 2026-06-15

Источников проанализировано 315

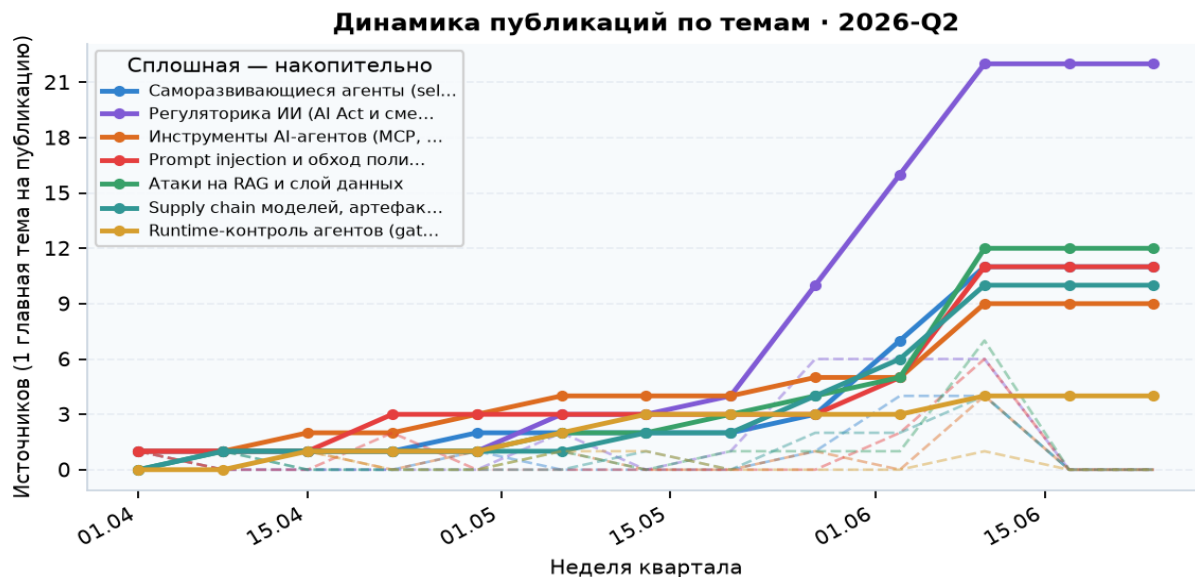
Инструмент: tendencia CLI

Краткое резюме для руководства

Тренд	Уверен.
Саморазвивающиеся агенты (self-evolving agents) Поведение агента меняется без релиза: новая поверхность для APT и insider-style атак. Классический change control и периметр не видят «тихую» эволюцию policy в memory.	High
Регуляторика ИИ (AI Act и смежные требования) Даже при отсрочке штрафных рамок организации должны проектировать agent/RAG-архитектуру под lifecycle security и post-market monitoring — иначе дорогой rework в 2027.	High
Инструменты AI-агентов (MCP, skills, tool-use) Агент = суперпользователь с LLM-интерфейсом. Компрометация одного MCP/skill даёт persistent access через mcp.json и cross-server tool shadowing.	High
Prompt injection и обход политик моделей Не нужен доступ к модели — достаточно untrusted content в browser/RAG/email pipeline.	High
Атаки на RAG и слой данных Model-level guardrails не спасают, если poisoned chunk попадает в retrieval.	Medium
Supply chain моделей, артефактов и skills Третья сторона в agent stack так же критична, как зависимости в CI/CD.	High
Runtime-контроль агентов (gateways, sandbox, policy) Единственный масштабируемый контроль при hundreds of MCP tools per agent.	Medium

Аналитика квартала

Темы (MCP, self-evolving agents, регуляторика...) и форматы публикаций (исследование, advisory, CVE-отчёт, новость) — разные оси. На графиках 1–2 каждый источник имеет одну главную тему; графики 3–4 показывают формат и его сочетание с темой.



Пунктир — новые публикации за неделю. Каждый источник отнесён к одной главной теме.

Рис. 1 — Динамика публикаций по темам (главная тема на источник)

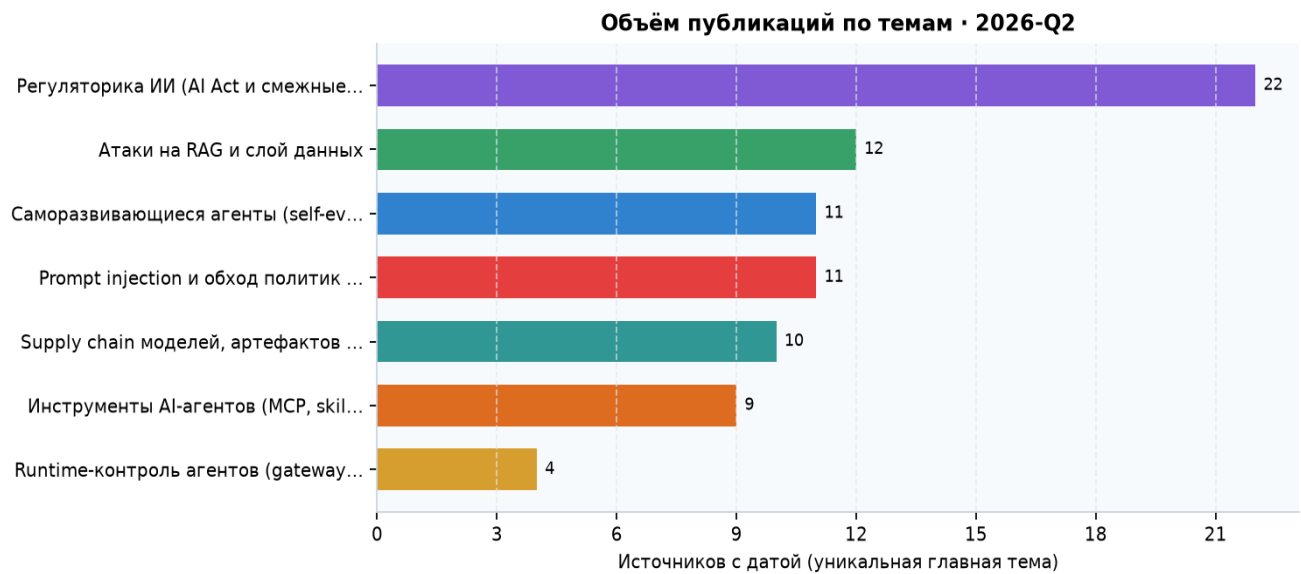


Рис. 2 — Объём публикаций по темам за квартал



Рис. 3 — Формат публикаций (тип источника)

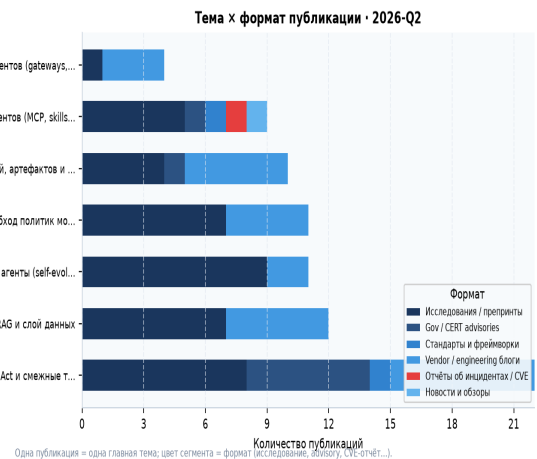


Рис. 4 — Тема × формат

Ландшафт угроз

Поверхность	Сигнал квартала
Модель и промпт	Prompt/indirect injection, jailbreaks
Агенты и инструменты	MCP, skills, delegated auth, tool abuse
RAG и данные	Poisoning, утечки через retrieval
Supply chain	Целостность моделей, зависимости, артефакты
Эксплуатация	Логирование агентов, IR, rate limits
Governance	AI Act, NIST/OWASP mapping, evals

Детальный разбор трендов (vs 2026-Q1)

1. Саморазвивающиеся агенты (self-evolving agents)

High

Суть

Self-evolving agents вышли из research в зону production-рисков. Исследования Q2 2026 формализуют «Zombie Agents» (persistent memory injection) и «misevolution» — непреднамеренную деградацию alignment при эволюции memory/tools/workflow. Unit 42 показал poisoning долговременной памяти: вредоносные инструкции переживают сессии и приоритизируются над user input.

Изменение к прошлому кварталу

Vs Q1 2026: от концептуальных surveys к эмпирическим работам (ICLR 2026 misevolution, Zombie Agents) и vendor PoC по memory poisoning.

Почему важно

Поведение агента меняется без релиза: новая поверхность для APT и insider-style атак. Классический change control и периметр не видят «тихую» эволюцию policy в memory.

Кому актуально

Владельцы agentic платформ, SOC, команды с long-term memory (coding/research agents).

Ключевые источники:

- When AI Remembers Too Much (Unit 42) — vendor (2026-05-01)
<https://unit42.paloaltonetworks.com/indirect-prompt-injection-poisons-ai-longterm-memory/>
- From Shield to Target: Denial-of-Service Attacks on LLM-Based Agent Guardrails — papers (2026-06-15)
<https://arxiv.org/abs/2606.14517>
- From Shield to Target: Denial-of-Service Attacks on LLM-Based Agent Guardrails — papers (2026-06-12)
<https://arxiv.org/abs/2606.14517v1>
- RAILS: Verification-Native Clearing For Agentic Commerce — papers (2026-06-07)
<https://arxiv.org/abs/2606.08790v1>
- VATS: Exploiting Implicit Authority in Error-Path Injection via Systematic Mutation — papers (2026-06-06)
<https://arxiv.org/abs/2606.07992v1>
- From Privacy to Workflow Integrity: Communication-Graph Metadata in Autonomous Agent Interoperability — papers (2026-06-05)
<https://arxiv.org/abs/2606.07150v1>

2. Регуляторика ИИ (AI Act и смежные требования)

High

Суть

В Q2 2026 EU согласовала Digital Omnibus: сроки high-risk obligations сдвинуты (Annex III → 2 Dec 2027, product-embedded → 2 Aug 2028), но Article 15 (accuracy, robustness, cybersecurity) остаётся ядром — data/model poisoning, adversarial examples. Связка с Cyber Resilience Act уточняется на уровне Council.

Изменение к прошлому кварталу

Vs Q1 2026: политический deal 7 May 2026 заменил «дедлайн паники» на фазовое планирование; фокус CISO — mapping technical controls на Art. 15.

Почему важно

Даже при отсрочке штрафных рамок организации должны проектировать agent/RAG-архитектуру под

lifecycle security и post-market monitoring — иначе дорогой rework в 2027.

Кому актуально

Compliance, legal, product owners в EU; глобальные вендоры с EU-клиентами.

Ключевые источники:

- Article 15: Accuracy, Robustness and Cybersecurity (EU AI Act) — standards (2026-04-01)
<https://artificialintelligenceact.eu/article/15/>
- AI Act: Digital Omnibus agreement (European Parliament) — gov_cert (2026-05-07)
https://www.europarl.europa.eu/pdfs/news/expert/2026/5/press_release/20260427IPR42011/20260427IPR42011_en.pdf
- Brickcom Cameras — gov_cert (2026-06-11)
<https://www.cisa.gov/news-events/ics-advisories/icsa-26-162-03>
- Jinan USR IOT Technology Limited (PUSR) USR-W610 RS232/485 to Wi-Fi/Ethernet Converter — gov_cert (2026-05-28)
<https://www.cisa.gov/news-events/ics-advisories/icsa-26-148-02>
- MacGregor Voyage Data Recorder (VDR) G4e — gov_cert (2026-05-28)
<https://www.cisa.gov/news-events/ics-advisories/icsa-26-148-01>
- XCharge C6 — gov_cert (2026-05-28)
<https://www.cisa.gov/news-events/ics-advisories/icsa-26-148-08>

3. Инструменты AI-агентов (MCP, skills, tool-use)

High

Суть

MCP стал de-facto стандартом tool-use (Cursor, Windsurf, VS Code). Q2 2026 — волна CVE (вкл. CVE-2026-30615 zero-click RCE в Windsurf), CSA notes по STUDIO RCE, npm supply-chain (WAVESHAPER). Аудит 2031 публичных MCP servers: ~40% с destructive/exec tools, 96% без предупреждений агенту. Skills/marketplace = новый software supply chain.

Изменение к прошлому кварталу

Vs Q1 2026: от «best practices» к documented exploit chains, CVE numeration и industry calls for transport-layer enforcement (agent gateways).

Почему важно

Агент = суперпользователь с LLM-интерфейсом. Компрометация одного MCP/skill даёт persistent access через mcp.json и cross-server tool shadowing.

Кому актуально

Dev platform teams, SecOps, все пользователи AI coding assistants.

Ключевые источники:

- MCP Security Crisis: Systemic Design (CSA) — standards (2026-05-04)
https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/05/CSA_research_note_MCP_security_crisis_20260504-csa-styled.pdf
- MCP STUDIO RCE: Supply Chain Risk (CSA) — gov_cert (2026-05-10)
https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/05/CSA_research_note_mcp-studio-rce-agentic-infrastructure_20260510-csa-styled.pdf
- CVE-2026-30615: Windsurf Zero-Click MCP Prompt Injection RCE — incidents (2026-04-15)
<https://policylayer.com/mcp-incidents/windsurf-zero-click-mcp-rce-cve-2026-30615>
- Beyond Attack Success Rate: Examining Trigger Leakage in Vision-Language Agentic Systems — papers (2026-06-10)
<https://arxiv.org/abs/2606.12586v1>
- RAILS: Verification-Native Clearing For Agentic Commerce — papers (2026-06-07)
<https://arxiv.org/abs/2606.08790v1>
- VATS: Exploiting Implicit Authority in Error-Path Injection via Systematic Mutation — papers (2026-06-06)
<https://arxiv.org/abs/2606.07992v1>

4. Prompt injection и обход политик моделей

High

Суть

Indirect injection эволюционировал в agent-specific цепочки: веб-страница → IDE context → изменение mcp.json → RCE (OX/Windsurf). Tool descriptions как скрытый канал инструкций (tool poisoning) подтверждён CSA и Invariant Labs cross-server сценариями.

Изменение к прошлому кварталу

Zero-click IDE RCE и CVE-цепочки — качественный скачок vs Q1 advisory-only.

Почему важно

Не нужен доступ к модели — достаточно untrusted content в browser/RAG/email pipeline.

Кому актуально

Enterprise с browser tools, email agents, публичные coding assistants.

Ключевые источники:

- MCP Security Crisis: Systemic Design (CSA) — standards (2026-05-04)
https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/05/CSA_research_note_MCP_security_crisis_20260504-csa-styled.pdf
- When AI Remembers Too Much (Unit 42) — vendor (2026-05-01)
<https://unit42.paloaltonetworks.com/indirect-prompt-injection-poisons-ai-longterm-memory/>
- CVE-2026-30615: Windsurf Zero-Click MCP Prompt Injection RCE — incidents (2026-04-15)
<https://policylayer.com/mcp-incidents/windsurf-zero-click-mcp-rce-cve-2026-30615>
- From Shield to Target: Denial-of-Service Attacks on LLM-Based Agent Guardrails — papers (2026-06-15)
<https://arxiv.org/abs/2606.14517>
- Patcher: Post-Hoc Patching of Backdoored Large Language Models — papers (2026-06-15)
<https://arxiv.org/abs/2606.02995>
- From Shield to Target: Denial-of-Service Attacks on LLM-Based Agent Guardrails — papers (2026-06-12)
<https://arxiv.org/abs/2606.14517v1>

5. Атаки на RAG и слой данных

Medium

Суть

RAG и слой данных остаются отдельной attack surface: document injection и memory summarization превращают «факты» в инструкции. Unit 42 и AWS Bedrock case studies показывают приоритет memory над user prompt.

Изменение к прошлому кварталу

Больше PoC на long-term memory, не только single-turn RAG.

Почему важно

Model-level guardrails не спасают, если poisoned chunk попадает в retrieval.

Кому актуально

RAG owners, data governance, teams с external crawlers.

Ключевые источники:

- MCP Security Crisis: Systemic Design (CSA) — standards (2026-05-04)
https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/05/CSA_research_note_MCP_security_crisis_20260504-csa-styled.pdf
- When AI Remembers Too Much (Unit 42) — vendor (2026-05-01)
<https://unit42.paloaltonetworks.com/indirect-prompt-injection-poisons-ai-longterm-memory/>

- Article 15: Accuracy, Robustness and Cybersecurity (EU AI Act) — standards (2026-04-01)
<https://artificialintelligenceact.eu/article/15/>
- Smarter Saboteurs, Better Fixers: Scaling & Security in Linear Multi-Agent Workflows — papers (2026-06-10)
<https://arxiv.org/abs/2606.12709v1>
- SMSR: Certified Defence Against Runtime Memory Poisoning in Persistent LLM Agent Systems — papers (2026-06-10)
<https://arxiv.org/abs/2606.12703v1>
- Zombie Agents: Persistent Control of Self-Evolving LLM Agents — papers (2026-02-15)
<https://arxiv.org/pdf/2602.15654>

6. Supply chain моделей, артефактов и skills

High

Суть

Supply chain skills/MCP/артефактов: 30+ CVE за 60 дней 2026, тысячи exposed servers (Shodan), 24k secrets в публичных mcp-конфигах (GitGuardian). North Korean npm hijack внедрял rogue MCP server.

Изменение к прошлому кварталу

Первый квартал с массовой CVE-нумерацией именно для MCP ecosystem.

Почему важно

Третья сторона в agent stack так же критична, как зависимости в CI/CD.

Кому актуально

AppSec, platform engineering, procurement third-party AI tools.

Ключевые источники:

- MCP STUDIO RCE: Supply Chain Risk (CSA) — gov_cert (2026-05-10)
https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/05/CSA_research_note_mcp-studio-rce-agentic-infrastructure_20260510-cs-a-styled.pdf
- Patcher: Post-Hoc Patching of Backdoored Large Language Models — papers (2026-06-15)
<https://arxiv.org/abs/2606.02995>
- SMSR: Certified Defence Against Runtime Memory Poisoning in Persistent LLM Agent Systems — papers (2026-06-10)
<https://arxiv.org/abs/2606.12703v1>
- Beyond Attack Success Rate: Examining Trigger Leakage in Vision-Language Agentic Systems — papers (2026-06-10)
<https://arxiv.org/abs/2606.12586v1>
- GitInject: Real-World Prompt Injection Attacks in AI-Powered CI/CD Pipelines — papers (2026-06-07)
<https://arxiv.org/abs/2606.09935v1>
- Supply Chain Compromises Impact Nx Console and GitHub Repositories — gov_cert (2026-05-28)
<https://www.cisa.gov/news-events/alerts/2026/05/28/supply-chain-compromises-impact-nx-console-and-github-repositories>

7. Runtime-контроль агентов (gateways, sandbox, policy)

Medium

Суть

Ответ индустрии: enforcement на transport layer — agent gateways, default-deny tool policy, JSON-RPC filtering, allowlist STUDIO binaries. Сдвиг от «надеемся на LLM safety» к out-of-process runtime control.

Изменение к прошлому кварталу

Vs Q1: зрелые product/category «agent gateway» и CSA red teaming guides.

Почему важно

Единственный масштабируемый контроль при hundreds of MCP tools per agent.

Кому актуально

Security architects внедряющих agentic AI.

Ключевые источники:

- The Meta-Agent Challenge: Are Current Agents Capable of Autonomous Agent Development? — papers (2026-06-03)
<https://arxiv.org/abs/2606.04455v1>
- Beyond Runtime Enforcement: Shield Synthesis as Defensibility Analysis for Adversarial Networks — papers (2026-06-11)
<https://arxiv.org/abs/2606.13621v1>
- Building a safe, effective sandbox to enable Codex on Windows — vendor (2026-05-13)
<https://openai.com/index/building-codex-windows-sandbox>
- Running Codex safely at OpenAI — vendor (2026-05-08)
<https://openai.com/index/running-codex-safely>
- The next evolution of the Agents SDK — vendor (2026-04-15)
<https://openai.com/index/the-next-evolution-of-the-agents-sdk>

Приоритетные рекомендации

- 1 Инвентаризация agent tools — каталог MCP/skills, owner, scope permissions.
- 2 Разделение trusted/untrusted контекста для RAG и browser/email tools.
- 3 Запрет неконтролируемого self-modification — approval на новые skills.
- 4 Мappings на AI Act / NIST AI RMF для high-risk use cases.
- 5 Red-teaming агентных сценариев: indirect injection + tool chain.

Метрики для мониторинга

- Количество активных MCP/skills и % с security review
- Инциденты tool invocation вне policy
- Доля ответов с retrieval из untrusted corpora
- Время реакции на новые vendor advisories по LLM

Открытые вопросы

- ? Насколько self-evolving agents станут production-default в 2026 H2?
- ? Будут ли industry-стандарты для MCP trust и signing в Q3–Q4?
- ? Какие метрики post-market monitoring примет регулятор для agentic systems?

Приложение: источники

MCP Security Crisis: Systemic Design (CSA)

standards · Cloud Security Alliance · 2026-05-04

https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/05/CSA_research_note_MCP_security_crisis_20260504-csa-styled.pdf

MCP STUDIO RCE: Supply Chain Risk (CSA)

gov_cert · Cloud Security Alliance · 2026-05-10

https://labs.cloudsecurityalliance.org/wp-content/uploads/2026/05/CSA_research_note_mcp-studio-rce-agentic-infrastructure_20260510-csa-styled.pdf

When AI Remembers Too Much (Unit 42)

vendor · Palo Alto Unit 42 · 2026-05-01

<https://unit42.paloaltonetworks.com/indirect-prompt-injection-poisons-ai-longterm-memory/>

Article 15: Accuracy, Robustness and Cybersecurity (EU AI Act)

standards · EU AI Act · 2026-04-01

<https://artificialintelligenceact.eu/article/15/>

CVE-2026-30615: Windsurf Zero-Click MCP Prompt Injection RCE

incidents · PolicyLayer / OX Security · 2026-04-15

<https://policylayer.com/mcp-incidents/windsurf-zero-click-mcp-rce-cve-2026-30615>

From Shield to Target: Denial-of-Service Attacks on LLM-Based Agent Guardrails

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.14517>

Patcher: Post-Hoc Patching of Backdoored Large Language Models

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.02995>

From Shield to Target: Denial-of-Service Attacks on LLM-Based Agent Guardrails

papers · arXiv · 2026-06-12

<https://arxiv.org/abs/2606.14517v1>

Smarter Saboteurs, Better Fixers: Scaling & Security in Linear Multi-Agent Workflows

papers · arXiv · 2026-06-10

<https://arxiv.org/abs/2606.12709v1>

SMSR: Certified Defence Against Runtime Memory Poisoning in Persistent LLM Agent Systems

papers · arXiv · 2026-06-10

<https://arxiv.org/abs/2606.12703v1>

Beyond Attack Success Rate: Examining Trigger Leakage in Vision-Language Agentic Systems

papers · arXiv · 2026-06-10

<https://arxiv.org/abs/2606.12586v1>

GitInject: Real-World Prompt Injection Attacks in AI-Powered CI/CD Pipelines

papers · arXiv · 2026-06-07

<https://arxiv.org/abs/2606.09935v1>

RAILS: Verification-Native Clearing For Agentic Commerce

papers · arXiv · 2026-06-07

<https://arxiv.org/abs/2606.08790v1>

VATS: Exploiting Implicit Authority in Error-Path Injection via Systematic Mutation

papers · arXiv · 2026-06-06

<https://arxiv.org/abs/2606.07992v1>

From Privacy to Workflow Integrity: Communication-Graph Metadata in Autonomous Agent Interoperability

papers · arXiv · 2026-06-05

<https://arxiv.org/abs/2606.07150v1>

The Meta-Agent Challenge: Are Current Agents Capable of Autonomous Agent Development?

papers · arXiv · 2026-06-03

<https://arxiv.org/abs/2606.04455v1>

Zombie Agents: Persistent Control of Self-Evolving LLM Agents

papers · arXiv · 2026-02-15

<https://arxiv.org/pdf/2602.15654>

Supply Chain Compromises Impact Nx Console and GitHub Repositories

gov_cert · CISA Cybersecurity Advisories · 2026-05-28

<https://www.cisa.gov/news-events/alerts/2026/05/28/supply-chain-compromises-impact-nx-console-and-github-repositories>

Malicious npm packages abuse dependency confusion to profile developer environments

vendor · Microsoft Security Blog · 2026-05-30

<https://www.microsoft.com/en-us/security/blog/2026/05/29/33-malicious-npm-packages-abuse-dependency-confusion-profile-developer-environments/>

AI Act: Digital Omnibus agreement (European Parliament)

gov_cert · European Parliament · 2026-05-07

https://www.europarl.europa.eu/pdfs/news/expert/2026/5/press_release/20260427IPR42011/20260427IPR42011_en.pdf

Brickcom Cameras

gov_cert · CISA Cybersecurity Advisories · 2026-06-11

<https://www.cisa.gov/news-events/ics-advisories/icsa-26-162-03>

Jinan USR IOT Technology Limited (PUSR) USR-W610 RS232/485 to Wi-Fi/Ethernet Converter

gov_cert · CISA Cybersecurity Advisories · 2026-05-28

<https://www.cisa.gov/news-events/ics-advisories/icsa-26-148-02>

MacGregor Voyage Data Recorder (VDR) G4e

gov_cert · CISA Cybersecurity Advisories · 2026-05-28

<https://www.cisa.gov/news-events/ics-advisories/icsa-26-148-01>

XCharge C6

gov_cert · CISA Cybersecurity Advisories · 2026-05-28

<https://www.cisa.gov/news-events/ics-advisories/icsa-26-148-08>

CP Plus 8 Ch. Network Video Recorder

gov_cert · CISA Cybersecurity Advisories · 2026-05-28

<https://www.cisa.gov/news-events/ics-advisories/icsa-26-148-05>

Software Dark Matter: Gazing at Uncharted Files to Navigate SBOM Integrations

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.13966>

Defending the Core: A Centrality-Based Protection Strategy for Supply Chain Security in npm Dependency Network

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.14036>

SkillMutator: Benchmarking and Defending Language-and-Code Cross-modal Attacks on LLM Agent Skills

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.14154>

REPOSE: Quantifying the Price of Security in Weakly-Hard Real-Time Cyber-Physical Systems

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.14395>

NeST: Neuron Selective Tuning for LLM Safety

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2602.16835>

Game-Theoretic Multi-Agent Control for Robust Contextual Reasoning in LLMs

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.10322>

RedAct: Redacting Agent Capability Traces for Procedural Skill Protection

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2606.10813>

The Insurability Frontier of AI Risk: Mapping Threats to Affirmative Coverage, Silent Exposures, and Exclusions

papers · arXiv cs.CR (snapshot) · 2026-06-15

<https://arxiv.org/abs/2605.18784>

SkillMutator: Benchmarking and Defending Language-and-Code Cross-modal Attacks on LLM Agent Skills

papers · arXiv · 2026-06-12

<https://arxiv.org/abs/2606.14154v1>

Beyond Runtime Enforcement: Shield Synthesis as Defensibility Analysis for Adversarial Networks

papers · arXiv · 2026-06-11

<https://arxiv.org/abs/2606.13621v1>